The Phishermen's White Team Documentation

About Us

Central Downtown City (CDC) operates the public transportation systems that serve the city's bus and rail network, supporting thousands of daily commuters traveling to work, school, and throughout the downtown area. The organization manages a diverse technology environment that includes ticketing kiosks, onboard scanning devices, operational control systems, and a recently introduced mobile application that allows riders to purchase and manage digital passes. These systems are connected through an internal network and external cloud services that enable real-time validation and service coordination. CDC's mission is to provide safe, reliable, and affordable transportation to the public.

Table of Contents

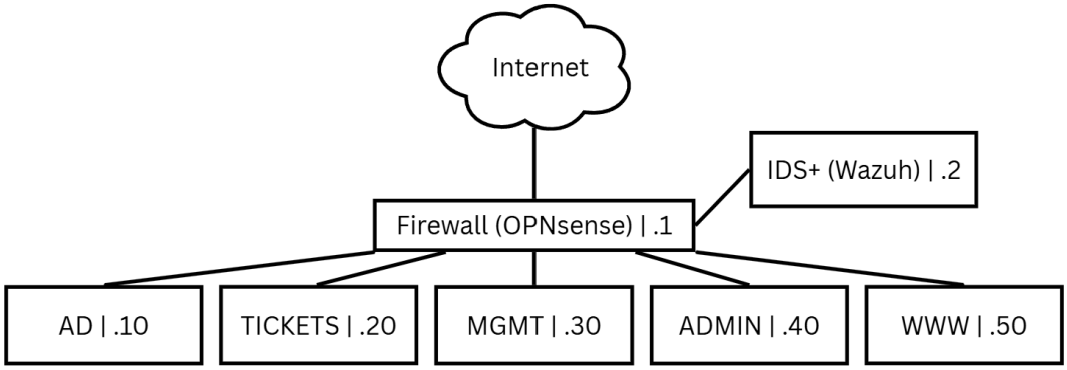
About Us **0**
Table of Contents **1**
Public Services **2**
Network Architecture **3**
Network Topology 3
WAN Rules 4
NAT: Port Forward 5
Servers **7**
Active Directory (Domain Controller) 7
Ticketing Machine (TICKETS) 7
Management Backend (MGMT) 8
Admin User Interface (ADMIN) 9
Website (WWW) 10

Public Services

Domain Name	IP	Port(s)
ad.team1.isucdc.com	64.39.3.10	RDP (3389)
tickets.team1.isucdc.com	64.39.3.20	RDP (3389)
mgmt.team1.isucdc.com	64.39.3.30	SSH (22)
admin.team1.isucdc.com	64.39.3.40	HTTP (80), RDP (3389)
www.team1.isucdc.com	64.39.3.50	SSH (22), HTTP (80)

Network Architecture

Network Topology



The network topology shown illustrates a segmented infrastructure built around a central OPNsense firewall acting as the primary gateway and security control point. All external traffic enters from the Internet and passes through OPNsense (.1), which handles routing, filtering, and network segmentation before distributing traffic internally. Connected to the firewall is an IDS (.2), positioned to monitor traffic for suspicious or malicious activity. The internal environment is divided into multiple isolated networks: AD (.10) for Active Directory and authentication services, TICKETS (.20) for ticketing or helpdesk systems, MGMT (.30) for infrastructure management and administrative control, ADMIN (.40) for privileged administrative workstations or services, and WWW (.50) for hosting web-facing applications or services. This design emphasizes separation of roles, reduced attack surface, and centralized visibility and control through the firewall and intrusion detection system.

WAN Rules

Allow/ Deny	Src	Src. Port	Destination External IP	Destination Internal IP	Dest. Port	Description
Allow	*	*	64.39.3.10	192.168.1.10	389	LDAP -> AD
Allow	*	*	64.39.3.10	192.168.1.10	636	LDAPS -> AD
Allow	*	*	64.39.3.10	192.168.1.10	3389	RDP -> AD
Allow	*	*	64.39.3.20	192.168.1.20	5000	HTTP -> TICKETS
Allow	*	*	64.39.3.20	192.168.1.20	3389	RDP -> TICKETS
Allow	*	*	64.39.3.30	192.168.1.30	5000	HTTP -> MGMT
Allow	*	*	64.39.3.30	192.168.1.30	22	SSH -> MGMT
Allow	*	*	64.39.3.40	192.168.1.40	80	HTTP -> ADMIN
Allow	*	*	64.39.3.40	192.168.1.40	3389	RDP -> ADMIN
Allow	*	*	64.39.3.50	192.168.1.50	80	HTTP -> WWW
Allow	*	*	64.39.3.50	192.168.1.50	22	SSH -> WWW
Allow	*	*	64.39.3.60	192.168.1.60	53	SECRET to resolve
Allow	*	*	64.39.3.2	192.168.1.2	443	HTTPS -> WAZUH
Deny	*	*	*	*	*	Implicit deny

WAN rules control which inbound traffic from the public internet is permitted to reach your network. When a packet arrives on one of your external IPs (64.39.3.x), the firewall checks these rules first. If a rule explicitly allows the source, protocol, and destination port, the traffic is permitted to proceed; if not, it is blocked immediately. WAN rules, therefore, serve as the front gate of

the network–only traffic you explicitly authorize, such as RDP to the AD server or HTTPS to the web server, is allowed through. Everything else is dropped before it ever reaches the internal LAN.

NAT: Port Forward

Interface	**Protocol**	**Destination Address**	**Ports**	**Description**
LAN	TCP	*	*	Anti-Lockout Rule
WAN	TCP	64.39.3.10	389	LDAP -> AD
WAN	TCP	64.39.3.10	3389	RDP -> AD
WAN	TCP`	64.39.3.10	636	LDAPS -> AD
WAN	TCP	64.39.3.20	5000	HTTP -> TICKETS
WAN	TCP	64.39.3.20	3389	RDP -> TICKETS
WAN	TCP	64.39.3.30	5000	HTTP -> MGMT
WAN	TCP	64.39.3.30	22	SSH -> MGMT
WAN	TCP	64.39.3.40	80	HTTP -> ADMIN
WAN	TCP	64.39.3.40	3389	RDP -> ADMIN
WAN	TCP	64.39.3.50	80	HTTP -> WWW
WAN	TCP	64.39.3.50	22	SSH -> WWW

NAT rules handle the translation and forwarding of that approved inbound traffic to the correct internal system. Once the WAN rule allows traffic to enter, the NAT rule determines which internal IP and port should receive it. For example, a NAT rule might forward 64.39.3.40:3389 on the WAN interface to

192.168.1.40:3389 inside the LAN. NAT is what makes internal services reachable externally while keeping internal addressing hidden.

Servers

Active Directory (Domain Controller)

Operating System: Windows Server 2016

About: The Active Directory server is the Domain Controller for the environment. It authenticates users, manages domain accounts, and allows all scenario users to log in across the network. All other machines rely on this server for LDAP authentication and directory services.

Security Changes:

- Removed the `Domain Users` group from the `Domain Admins` group to prevent all `Domain Users` from having the same privileges as `Domain Admins`.
- Removed the `Transit Admins` group from the `Domain Admins` group to prevent all `Transit Admins` from having the same privileges as `Domain Admins.`
- Disabled SMBv1 to protect against EternalBlue
- Restricted Remote Desktop Protocol (RDP) access to `IT Administrators`, per the provided Scenario.

Ticketing Machine (TICKETS)

Operating System: Windows Server 2019

About: The Ticketing Machine server runs the core infrastructure behind the city's fare system, handling ticket creation, validation, and enforcement for buses and trains, while also communicating directly with the ticket scanners installed on vehicles and throughout transit stations.

Security Changes:

- Machine Changes:
    - Removed sus.exe executable from startup
    - Removed `backdoor` and `scrat` malicious users
- Codebase Changes:
    - Migrated HTTP to HTTPS
    - Added authentication to select endpoints

Management Backend (MGMT)

Operating System: Alma Linux 8.4

About: The Management Backend server serves as the central management backend for the city's transit system, supporting both user-facing applications while handling authentication, fare payments, and the administration of vehicles, routes, and overall transit operations.

Security Changes:

- Machine Changes:
    - Revised `/etc/sudoers` file to only allow for `IT Administrators` and root to run commands with elevated permissions.
- Codebase Changes:
    - Updated SECRET_KEY to use a secure, 32-bit hex string
        - Originally: `SECRET_KEY = "cdc"`

        - Patched: `os.environ.get("SECRET_KEY", secrets.token_hex(32))`
    - Disabled Authentication Bypass to Administrator
        - Originally: `success = authenticate(username, password)`

            `is_admin = True`
        - Patched: `success, is_admin = authenticate(username, password)`
    - Disabled Remote Code Execution via Debug Mode
        - Originally: `app.wsgi_app = DebuggedApplication(app.wsgi_app, evalex=True)`
        - Patched: `app.wsgi_app = DebuggedApplication(app.wsgi_app, evalex=False)`
    - Updated LDAP Bind user from Administrator to a low-privilege user
    - Updated package requirements to use non-vulnerable versions (PyMySQL 1.1.0 (CVE-2024-36039) → 1.1.1)

Admin User Interface (ADMIN)

Operating System: Windows Server 2022

About: The Admin User Interface server hosts the city's administrative portal, providing operators with visibility into the current state of the transportation system and the tools needed to monitor and manage the active vehicle fleet.

Security Changes:

- Machine Changes:
    - Deleted malicious users `scrat` and `taco`

    - Deleted malicious `notpad_original.exe` and `backdoor.bat` files
- Codebase Changes:
    - Updated SECRET_KEY to use a secure, 32-bit hex string
        - Originally: `SECRET_KEY = "cdc"`
        - Patched: `os.environ.get("SECRET_KEY", secrets.token_hex(32))`
    - Disabled Remote Code Execution via Debug Mode
        - Originally: `app.wsgi_app = DebuggedApplication(app.wsgi_app, evalex=True)`
        - Patched: `app.wsgi_app = DebuggedApplication(app.wsgi_app, evalex=False)`

Website (WWW)

Operating System: Alma Linux 9

About: The Website server runs the city's public-facing website, where riders can create accounts, browse bus and train routes, manage their profile, purchase tickets, and present digital tickets for scanning.

Security Changes:

- Machine Changes:
    - Removed `nsabackdoor.so LD_PRELOAD`
    - Removed three (3) listening ports running netcat (nc), which would allow for an immediate root reverse shell
    - Removed two services in systemd which allow for immediate privileged access
    - Revised `/etc/sudoers` file to only allow for `IT Administrators` and root to run commands with elevated permissions.

- Codebase Changes:
    - Updated SECRET_KEY to use a secure, 32-bit hex string
        - Originally: `SECRET_KEY = “cdc”`
        - Patched: `os.environ.get("SECRET_KEY", secrets.token_hex(32))`
    - Enabled SESSION_COOKIE_HTTPONLY
        - Originally: `SESSION_COOKIE_HTTPONLY = False`
        - Patched: `SESSION_COOKIE_HTTPONLY = True`